NORTHWIND BANK LIMITED
INFORMATION SECURITY STANDARD (FICTIONAL SAMPLE, VERSION 2.0)

1. Scope. This standard applies to all Bank systems and to every vendor system that stores or processes Bank data.

2. Access control. Multi-factor authentication is mandatory for all remote access and for all privileged accounts. Privileged access rights are reviewed every quarter. Access for employees who leave the Bank must be revoked within 24 hours of their exit. Passwords must be at least 14 characters long; periodic forced password changes are not required, but passwords must be changed immediately if a compromise is suspected.

3. Encryption. Data at rest must be encrypted with AES-256. Data in transit must use TLS 1.2 or higher. Encryption keys must be stored in a hardware security module or a managed key service and rotated at least once a year.

4. Logging and monitoring. Security logs from all critical systems must be retained for at least 180 days and must be monitored by the security operations centre around the clock.

5. Backups and recovery. Critical systems are backed up every day, and restores are tested every quarter. For critical systems the recovery point objective (RPO) is four hours and the recovery time objective (RTO) is eight hours.

6. Incident response. Security incidents are classified by severity. Cyber security incidents must be reported to CERT-In and to the Reserve Bank of India within six hours of being noticed. Customers whose personal data is affected by a breach must be informed within 72 hours.

7. Vendor security. Critical vendors must undergo a security assessment every year and must hold a current ISO 27001 certificate or a SOC 2 Type II report.

8. Exceptions. Exceptions to this standard must be approved by the Chief Information Security Officer (CISO) and are valid for at most 90 days.